UNIVERSIDADE ESTADUAL DO TOCANTINS
CURSO DE SISTEMAS DE INFORMAÇÃO

ALÊKSON CASTRO DE SOUZA

CONTROLE DE ACESSO IOT NA GESTÃO IMOBILIÁRIA VIA DSR

Palmas
2026

Dados Internacionais de Catalogação na Publicação (CIP)
Sistema Integrado de Bibliotecas da Universidade Estadual do Tocantins (SIBU)

S729c Souza, Alêkson Castro de.
Controle de acesso IoT na gestão imobiliária via DSR / Alêkson Castro de Souza. – Palmas, TO, 2026.
46 f. : il.
Orientadora: Profa. Me. Tamirys Virgulino.

Trabalho de Conclusão de Curso (Graduação em Sistemas de Informação) – Universidade Estadual do Tocantins, 2026.
1. Internet das Coisas (IoT). 2. Controle de acesso. 3. Gestão imobiliária. 4. Criptografia Ed25519. 5. Design Science Research. I. Virgulino, Tamirys, orient. II. Universidade Estadual do Tocantins. III. Título.

CDU 004.738.5:681.518

UNIVERSIDADE ESTADUAL DO TOCANTINS
CURSO DE SISTEMAS DE INFORMAÇÃO

ALÊKSON CASTRO DE SOUZA

CONTROLE DE ACESSO IOT NA GESTÃO IMOBILIÁRIA VIA DSR

Trabalho de Conclusão de Curso apresentado ao Curso de Sistemas de Informação da Universidade Estadual do Tocantins como requisito parcial para obtenção do título de Bacharel.

Orientadora: Profa. Me. Tamirys Virgulino

Palmas
2026

ALÊKSON CASTRO DE SOUZA

CONTROLE DE ACESSO IOT NA GESTÃO IMOBILIÁRIA VIA DSR

Trabalho de Conclusão de Curso apresentado ao Curso de Sistemas de Informação da Universidade Estadual do Tocantins como requisito parcial para obtenção do título de Bacharel.

Aprovado em: _____ de _____ de 2026.

BANCA EXAMINADORA

Profa. Me. Tamirys Virgulino (Orientadora)
Universidade Estadual do Tocantins – UNITINS

Prof(a). Me./Dr(a). [Membro da Banca 1]
Universidade Estadual do Tocantins – UNITINS

Prof(a). Me./Dr(a). [Membro da Banca 2]
Universidade Estadual do Tocantins – UNITINS

Resumo

O modelo operacional de imobiliárias que gerenciam múltiplos corretores parceiros enfrenta um gargalo crítico no controle de acesso físico a propriedades dispersas. O compartilhamento tradicional de chaves metálicas e senhas de cofres mecânicos carece de rastreabilidade e apresenta riscos severos à segurança patrimonial. Embora fechaduras inteligentes conectadas mitiguem a distribuição de chaves, soluções vigentes pressupõem conectividade contínua à internet, inviabilizando sua aplicação no cenário mais frequente do setor: imóveis desocupados sem plano ativo de banda larga. Este trabalho propõe e avalia, sob a metodologia Design Science Research (DSR), um artefato de controle de acesso inteligente baseado em Internet das Coisas (IoT), validado em ambiente simulado, capaz de gerenciar com segurança o acesso temporário de múltiplos parceiros a imóveis desprovidos de conexão de rede. A solução integra controle de acesso baseado em atributos (ABAC contextual) a tokens criptográficos assinados digitalmente com o algoritmo de curva elíptica Ed25519, transmitidos via QR Code e verificados localmente pelo microcontrolador da fechadura em milissegundos, com sincronização assíncrona de auditoria via protocolo MQTT. A avaliação do artefato é estruturada por meio de simulação virtual em nós microcontrolados e testes automatizados de integração, estabelecendo métricas de latência temporal, ocupação de memória e eficácia de contenção lógica, com o intuito de fundamentar uma alternativa arquitetural de baixo custo e auditável no setor imobiliário.

Palavras-chave: Internet das Coisas (IoT). Controle de Acesso. Gestão Imobiliária. Criptografia Ed25519. Design Science Research.

Abstract

The operational model of real estate agencies managing multiple partner brokers faces a critical bottleneck in physical access control to dispersed properties. Traditional sharing of physical keys and lockbox passcodes lacks traceability and poses severe security risks. Although connected smart locks mitigate key handover logistics, current IoT solutions rely on continuous internet connectivity, failing in the sector's most common scenario: vacant properties without active broadband connections. This work proposes and evaluates, following the Design Science Research (DSR) methodology, an Internet of Things (IoT) intelligent access control artifact, validated in a simulated environment, capable of securely managing temporary access for multiple partners to offline properties. The solution couples Attribute-Based Access Control (contextual ABAC) with cryptographic tokens digitally signed via the Ed25519 elliptic curve algorithm, delivered through QR Codes and verified locally by the microcontrolled lock within milliseconds, alongside asynchronous audit synchronization via the MQTT protocol. The artifact evaluation is structured through virtual microcontroller simulation and automated integration tests, establishing performance metrics for latency, memory footprint, and logical containment efficacy, aiming to support an auditable and cost-effective architectural alternative tailored for real estate operations.

Keywords: Internet of Things (IoT). Access Control. Real Estate Management. Ed25519 Cryptography. Design Science Research.

Lista de abreviaturas e siglas

ABAC	*Attribute-Based Access Control* (Controle de Acesso Baseado em Atributos)
AES	*Advanced Encryption Standard* (Padrão de Criptografia Avançada)
API	*Application Programming Interface* (Interface de Programação de Aplicação)
ARM	*Advanced RISC Machine* (Arquitetura de Processadores Embarcados)
BC-SNOA	*Blockchain-based Secure and Non-interactive Offline Authentication*
BLE	*Bluetooth Low Energy* (Bluetooth de Baixa Energia)
DSR	*Design Science Research* (Metodologia de Pesquisa do Artefato)
ECC	*Elliptic Curve Cryptography* (Criptografia de Curva Elíptica)
ECDSA	*Elliptic Curve Digital Signature Algorithm*
Ed25519	*Edwards-curve Digital Signature Algorithm 25519*
ESP32	Microcontrolador de Baixo Custo com Wi-Fi e Bluetooth Integrados
HABAC	*Hierarchical Attribute-Based Access Control*
HMAC	*Hash-based Message Authentication Code*
HTTP	*Hypertext Transfer Protocol*
IoT	*Internet of Things* (Internet das Coisas)
JSON	*JavaScript Object Notation* (Formato de Carga Útil do Token)
MQTT	*Message Queuing Telemetry Transport* (Protocolo de Mensageria Leve)
OTMP-P2L	*One-Time Multi-Party Proof to Lock*
OTP	*One-Time Password* (Senha de Uso Único)
PoW	*Proof of Work* (Prova de Trabalho Criptográfica)
QR Code	*Quick Response Code* (Código Bidimensional de Transporte do Token)
RBAC	*Role-Based Access Control* (Controle de Acesso Baseado em Papéis)
SHA	*Secure Hash Algorithm* (Função Hash Criptográfica)
TLS	*Transport Layer Security* (Segurança da Camada de Transporte)
TTL	*Time-To-Live* (Tempo de Vida Útil do Token)
Wi-Fi	*Wireless Fidelity* (Rede Local sem Fio)
zk-SNARK	*Zero-Knowledge Succinct Non-Interactive Argument of Knowledge*

Sumário

1 INTRODUÇÃO 10
1.1 Contextualização 10
1.2 Problema de Pesquisa 11
1.3 Objetivo Geral 11
1.4 Objetivos Específicos 12
1.5 Justificativa 12
1.6 Estrutura do Trabalho 12

2 FUNDAMENTAÇÃO TEÓRICA 13
2.1 Internet das Coisas (IoT): Conceitos e Arquitetura 13
2.1.1 Definição e Desafios em Dispositivos Conectados 13
2.1.2 Arquitetura em Camadas e Gateways de Borda 13
2.1.3 Protocolo de Mensageria Leve: MQTT 14
2.2 Controle de Acesso em Ambientes IoT 15
2.2.1 Controle de Acesso Baseado em Papéis (RBAC) e Suas Limitações 15
2.2.2 Controle de Acesso Baseado em Atributos (ABAC) e o Modelo HABACα . 15
2.2.3 Autenticação Temporária por Tokens Efêmeros 16
2.2.4 Criptografia Assimétrica e Verificação Offline em Dispositivos de Borda . . 16
2.3 Fechaduras Inteligentes e Trabalhos Relacionados 17
2.3.1 Limitações dos Mecanismos Tradicionais de Acesso Físico 17
2.3.2 Sistemas de Fechaduras Baseados em IoT 17
2.3.3 Análise Comparativa do Estado da Arte 19
2.4 Segurança, Rastreabilidade e Auditoria em Sistemas IoT 20
2.4.1 Vetores de Ataque e Vulnerabilidades Comuns 20
2.4.2 Mecanismos de Proteção e Trilhas de Auditoria 20

3 METODOLOGIA E DESENVOLVIMENTO DO ARTEFATO 22
3.1 Caracterização Metodológica 22
3.1.1 Design Science Research como Paradigma de Pesquisa 22
3.1.2 Mapeamento das Fases do DSR no Trabalho 23
3.2 Contexto e Formalização do Problema 23
3.2.1 O Cenário de Gestão de Visitas em Imóveis Desocupados 23
3.2.2 Análise Crítica dos Métodos Convencionais no Contexto do Problema . . . 24
3.2.3 Definição do Problema e Questão de Pesquisa 24
3.2.4 Requisitos e Pilares de Concepção do Artefato 24
3.3 Arquitetura Geral do Artefato 25

3.3.1 Visão em Camadas do Ecossistema IoT . . . 25
3.3.2 Componentes Arquiteturais e Responsabilidades . . . 26
3.4 Modelo de Autorização Baseado em Atributos (ABAC) . . . 28
3.4.1 Fundamentação: Do RBAC ao ABAC . . . 28
3.4.2 Entidades e Dicionário de Atributos do Sistema . . . 28
3.4.3 Arquitetura Funcional segundo o Padrão NIST SP 800-162 . . . 28
3.4.4 Formalização das Regras de Acesso e Algoritmo de Decisão . . . 30
3.5 Modelo Criptográfico e Validação Offline . . . 31
3.5.1 O Princípio da Validação Desconectada (Analogia EMV) . . . 31
3.5.2 Seleção Criptográfica: Justificativa do Algoritmo Ed25519 . . . 31
3.5.3 Estrutura do Token de Acesso . . . 31
3.5.4 Algoritmo de Verificação Local no ESP32 . . . 33
3.5.5 Prevenção contra Ataques e Gestão do Buffer Anti-Replay . . . 34
3.6 Fluxo de Operação de Ponta a Ponta . . . 34
3.6.1 Fase 1: Solicitação e Emissão do Token (Online) . . . 34
3.6.2 Fase 2: Apresentação e Validação Local (Offline) . . . 36
3.6.3 Fase 3: Sincronização Assíncrona e Auditoria . . . 36
3.7 Stack Tecnológica e Especificação do Firmware . . . 37
3.7.1 Mapeamento dos Componentes Tecnológicos . . . 37
3.7.2 Organização Modular do Firmware no ESP32 . . . 37
3.7.3 Endpoints e Motor de Inferência em FastAPI . . . 38
3.7.4 Estrutura de Mensageria e Tópicos MQTT . . . 38
3.8 Ambiente de Simulação Virtual no Wokwi . . . 39
3.8.1 Justificativa Metodológica da Prototipagem Virtual . . . 39
3.8.2 Mapeamento do Circuito Eletrônico e Pinout . . . 39
3.9 Cenários de Demonstração DSR . . . 41
3.9.1 Cenário 1: Concessão de Acesso Válido em Horário Permitido . . . 41
3.9.2 Cenário 2: Negação de Acesso sob Condições Inválidas e Tentativas de Ataque 41
3.9.3 Cenário 3: Revogação Emergencial de Credenciais . . . 42
3.10 Métricas e Procedimentos de Avaliação . . . 42
3.10.1 Métricas Quantitativas de Desempenho e Segurança . . . 42
3.10.2 Procedimento Experimental e Tratamento Estatístico . . . 42

4 RESULTADOS E DISCUSSÃO . . . 44
4.1 Introdução . . . 44
4.2 Apresentação de resultados . . . 44

5 CONCLUSÃO . . . 45
5.1 Trabalhos futuros . . . 45

REFERÊNCIAS 46

1 Introdução

1.1 Contextualização

O mercado imobiliário apoia-se em redes colaborativas de intermediação, nas quais administradoras gerenciam carteiras extensas de propriedades distribuídas geograficamente. Para viabilizar a comercialização e a locação desse patrimônio, as empresas dependem da atuação de dezenas de corretores autônomos e parceiros externos. Essa atividade impõe uma dinâmica operacional ágil e imprevista: visitas a imóveis costumam ser solicitadas por clientes em janelas de tempo reduzidas, com frequência fora do horário comercial, como no início da noite, intervalos de almoço ou finais de semana. Paralelamente às visitas comerciais, o ecossistema demanda acesso frequente para vistorias técnicas, serviços de limpeza, reparos de manutenção e registros fotográficos para divulgação em plataformas digitais.

Apesar da modernização dos sistemas de gestão e dos portais de anúncio, o controle de acesso físico às propriedades permanece dependente de métodos convencionais, centralizado no uso de chaves metálicas. Na prática, quando um corretor parceiro agenda um atendimento, precisa deslocar-se previamente até a sede da imobiliária para retirar o molho de chaves da unidade, assinar fichas de protocolo em papel, dirigir-se ao imóvel para a demonstração e, em seguida, retornar à sede para restituir o chaveiro. Esse procedimento gera atrito logístico constante: consome tempo excessivo em deslocamentos no trânsito, eleva despesas com combustível e frequentemente inviabiliza visitas quando a imobiliária encontra-se fechada, gerando perda de oportunidades comerciais.

Para contornar essa lentidão operacional, o mercado recorre a soluções de contingência frágeis, como deixar cópias com porteiros de condomínios sob guarda de terceiros ou instalar cofres mecânicos com segredo numérico (*lockboxes*) presos a portões externos. Chaves físicas podem ser duplicadas em chaveiros comuns em poucos minutos sem qualquer registro formal (SILVA; SAMANIEGO; DETERS, 2023). Já os cofres mecânicos utilizam senhas estáticas de quatro dígitos compartilhadas informalmente por aplicativos de mensagens instantâneas entre dezenas de profissionais, combinações que raramente são alteradas e mantêm o acesso aberto a corretores desvinculados por meses (SATANASAOWAPAK; MANASATHIEN; TREEBUPACHATSAKUL, 2021). O principal agravante desse cenário reside na total ausência de auditoria: caso ocorram avarias, torneiras abertas ou furtos de fiação, a administração não dispõe de meios para apurar quem acessou a unidade, em qual data e quanto tempo permaneceu no local.

A alternativa intuitiva seria a adoção de fechaduras inteligentes conectadas ao ecossistema de Internet das Coisas (*Internet of Things* – IoT). Entretanto, as opções comerciais vigentes foram projetadas para residências habitadas, operando sob a premissa de conexão ininterrupta a

redes locais sem fio (Wi-Fi) vinculadas à nuvem (VARDAKIS et al., 2024). Esse modelo colide com a realidade do setor: imóveis desocupados ofertados para venda ou locação encontram-se desprovidos de planos de banda larga fixa, visto que proprietários e administradores evitam assumir custos mensais de conexão durante o período de vacância. Sem infraestrutura de rede local no imóvel, os dispositivos convencionais tornam-se inoperantes ou recuam para o uso das mesmas chaves físicas, neutralizando os benefícios da automação.

Diante do dilema entre a necessidade de delegação ágil e a inexistência de conectividade no local, este trabalho desenvolve uma resposta arquitetural ao problema. A abordagem transfere a camada de conectividade para o único elemento provido de internet no instante da visita: o smartphone do corretor, que dispõe de conexão móvel celular (4G/5G). A fechadura embarcada opera de forma estritamente offline, utilizando criptografia de curvas elípticas (Ed25519) e avaliação dinâmica de políticas por atributos (ABAC contextual). O corretor requisita a permissão à nuvem, recebe o token assinado e o apresenta localmente via leitura óptica de QR Code; o microcontrolador valida a credencial matematicamente e aciona o destravamento, permitindo a sincronização assíncrona dos registros de auditoria via protocolo MQTT. A pesquisa é conduzida sob a metodologia *Design Science Research* (DSR), orientando a concepção teórica, a implementação em bancada simulada e a avaliação experimental do artefato.

1.2 Problema de Pesquisa

O problema que orienta esta pesquisa desdobra-se em duas dimensões complementares: a operacional, decorrente da ausência de mecanismos centralizados e auditáveis para gerenciar o acesso temporário de parceiros; e a técnica, decorrente da exigência de conexão de rede nas soluções IoT convencionais, inoperantes em imóveis desocupados.

Diante desse cenário, define-se a seguinte pergunta de pesquisa:

> *Como projetar e avaliar uma arquitetura de controle de acesso inteligente baseada em IoT capaz de gerenciar, de forma segura, rastreável e orientada a atributos (ABAC), o acesso temporário de múltiplos corretores parceiros a imóveis desocupados desprovidos de conexão à internet?*

1.3 Objetivo Geral

Projetar e avaliar, por meio da metodologia *Design Science Research* (DSR), um artefato IoT de controle de acesso que permita a imobiliárias gerenciar com segurança e rastreabilidade o acesso de corretores parceiros a imóveis offline, utilizando tokens assinados com o algoritmo Ed25519, validados em ambiente simulado.

1.4 Objetivos Específicos

1. **Mapear o estado da arte** em autenticação offline, mensageria leve com MQTT (*Message Queuing Telemetry Transport*) e criptografia de curva elíptica (ECC – *Elliptic Curve Cryptography*), de modo a fundamentar as decisões arquiteturais da proposta.

2. **Modelar a arquitetura** do sistema em camadas, integrando controle de acesso baseado em atributos (ABAC contextual – *Attribute-Based Access Control*) a tokens Ed25519 verificáveis offline.

3. **Implementar o protótipo simulado** cobrindo os cenários de acesso concedido, negado por violação de atributo e revogado.

4. **Avaliar o protótipo** quanto à latência de verificação offline da assinatura Ed25519 no microcontrolador e à latência de comunicação MQTT na fase de emissão do token, além da eficácia na contenção de acessos indevidos.

1.5 Justificativa

Os problemas mapeados na contextualização não são independentes: a falha operacional, o risco de segurança e a limitação tecnológica se reforçam mutuamente, e nenhuma solução disponível os endereça de forma integrada. É nessa interseção que o presente trabalho se posiciona, com justificativa distribuída em três planos:

Plano prático. A substituição de chaves físicas e senhas estáticas de *lockboxes* elimina riscos de cópia não autorizada (SATANASAOWAPAK; MANASATHIEN; TREEBUPACHATSAKUL, 2021) e reduz a dependência de plataformas proprietárias sujeitas a vazamento de credenciais (SILVA; SAMANIEGO; DETERS, 2023), assegurando à imobiliária controle e auditoria confiáveis.

Plano técnico. Demonstra-se viável executar verificação criptográfica assimétrica por curvas elípticas (ECC) de maneira estritamente offline em microcontroladores de baixo custo, com tempo de resposta na ordem de milissegundos (HAN et al., 2018; HAN; DU; LU, 2020).

Plano acadêmico. O estudo preenche a lacuna de integrar autenticação offline, políticas baseadas em atributos (ABAC contextual) e sincronização assíncrona de auditoria sob uma arquitetura voltada ao setor imobiliário.

1.6 Estrutura do Trabalho

O trabalho organiza-se em cinco capítulos: o Capítulo 2 apresenta a fundamentação teórica e os trabalhos correlatos; o Capítulo 3 descreve o método DSR adotado; o Capítulo 4 apresenta a arquitetura, o protótipo simulado e a avaliação experimental; e o Capítulo 5 sintetiza as contribuições e propõe trabalhos futuros.

2 Fundamentação Teórica

Este capítulo apresenta a base teórica e tecnológica que sustenta a concepção e a modelagem do artefato proposto neste trabalho. A discussão está estruturada em quatro eixos temáticos: (i) Internet das Coisas (IoT), sua arquitetura em camadas e protocolos de mensageria leve; (ii) modelos de controle de acesso e autorização dinâmica em ambientes computacionais restritos, incluindo a criptografia assimétrica para validação offline em dispositivos de borda; (iii) fechaduras inteligentes, acompanhadas de análise comparativa do estado da arte, com ênfase em esquemas de autenticação sem conectividade de rede; e (iv) segurança, rastreabilidade e trilhas de auditoria em ecossistemas IoT.

2.1 Internet das Coisas (IoT): Conceitos e Arquitetura

2.1.1 Definição e Desafios em Dispositivos Conectados

A Internet das Coisas (*Internet of Things* – IoT) consiste na interconexão digital de objetos físicos à infraestrutura de rede, permitindo que sensores, atuadores e microcontroladores realizem a coleta, o processamento e a troca autônoma de dados sem intervenção humana contínua (VARDAKIS et al., 2024).

Entretanto, Vardakis et al. (2024) e Researchers (2022) ressaltam que o avanço da IoT expõe desafios críticos de segurança decorrentes da heterogeneidade e da severa restrição computacional dos nós de borda. Ao contrário de servidores de aplicação ou estações de trabalho, dispositivos embarcados em extremidades de rede operam com processadores de baixo custo, memória volátil reduzida e capacidade energética limitada. Tal restrição inviabiliza a execução local de pilhas criptográficas complexas ou algoritmos pesados de avaliação de políticas de segurança (RESEARCHERS, 2021).

Diante desse cenário, torna-se imperativo projetar arquiteturas computacionais que dissociem a tarefa de decisão de acesso da tarefa de atuação física. Essa diretriz fundamenta diretamente o desenvolvimento do presente trabalho, no qual o dispositivo de acionamento da trava no imóvel atua exclusivamente na execução de ordens validadas previamente por uma infraestrutura centralizada.

2.1.2 Arquitetura em Camadas e Gateways de Borda

A literatura científica adota predominantemente a representação de sistemas IoT organizada em quatro camadas hierárquicas, estruturando o fluxo de dados desde a captura física até a interação com o usuário final (VARDAKIS et al., 2024):

1. **Camada Física e de Percepção:** Abrange o hardware embarcado, atuadores mecânicos (fechaduras elétricas ou solenóides), sensores de presença e leitores de entrada de credenciais (interfaces de leitura de QR Code, biometria ou teclados).

2. **Camada de Rede:** Fornece a infraestrutura de transmissão de dados via enlaces locais (Wi-Fi, Bluetooth) ou remotos, conectando dispositivos locais aos servidores de controle por meio de protocolos de transporte e aplicação dedicados.

3. **Camada de Middleware e Processamento:** Responsável pelo processamento lógico, aplicação de políticas de autorização, gerenciamento de regras temporais e persistência de dados.

4. **Camada de Aplicação:** Engloba os painéis administrativos web e aplicativos móveis voltados aos administradores imobiliários e aos corretores autorizados.

Para mitigar a vulnerabilidade decorrente da exposição direta de microcontroladores à internet pública, Vardakis et al. (2024) e Ameer et al. (2022) preconizam a inserção de um *gateway* local ou de borda (*edge gateway*). O gateway centraliza a comunicação local, atua como intermediário na validação criptográfica e isola os dispositivos físicos de varreduras externas de rede.

2.1.3 Protocolo de Mensageria Leve: MQTT

O MQTT (*Message Queuing Telemetry Transport*) é um protocolo de mensageria assíncrona baseado no padrão de publicação e subscrição (*publish/subscribe*), concebido especificamente para redes com largura de banda limitada e dispositivos com recursos restritos (AMEER et al., 2022). No modelo MQTT, clientes publicam mensagens associadas a tópicos específicos em um intermediário central (*broker*), o qual roteia os dados unicamente para os clientes previamente inscritos nesses mesmos canais de interesse.

Em sistemas de segurança física, o MQTT viabiliza o envio imediato e bidirecional de comandos e telemetrias com sobrecarga (*overhead*) de cabeçalho substancialmente inferior àquela gerada pelo protocolo HTTP tradicional (AUTHORS, 2024). Ameer et al. (2022) demonstraram que a aplicação de MQTT combinada à criptografia de transporte via TLS (*Transport Layer Security*) oferece canais resilientes e com tempos de propagação de mensagens da ordem de milissegundos, impedindo a interceptação passiva e a adulteração de comandos de acionamento. Ademais, Researchers (2024) validam experimentalmente que o MQTT associado a microcontroladores como o ESP32 mantém estabilidade de latência em cenários simulados de controle de tráfego.

Essa eficiência operacional orienta a escolha do MQTT no artefato deste estudo, viabilizando o despacho em tempo real do evento de abertura para a fechadura imediatamente após a validação da permissão do corretor pelo servidor.

2.2 Controle de Acesso em Ambientes IoT

2.2.1 Controle de Acesso Baseado em Papéis (RBAC) e Suas Limitações

O modelo de Controle de Acesso Baseado em Papéis (*Role-Based Access Control* – RBAC) fundamenta-se na concessão de privilégios a determinados papéis organizacionais (*roles*), atribuindo posteriormente os usuários a essas categorias pré-definidas (AMEER et al., 2022). Trata-se do padrão amplamente implementado em sistemas de informação corporativos tradicionais devido à simplicidade administrativa inicial que oferece.

Contudo, investigações recentes apontam que o RBAC apresenta rigidez excessiva quando transposto para ambientes ubíquos e IoT dinâmicos (AMEER et al., 2022; RESEARCHERS, 2021). Em um ecossistema imobiliário, por exemplo, a atribuição estática do papel "Corretor" revela-se insuficiente para a segurança da operação: conceder acesso ilimitado com base apenas na função profissional impediria restringir o acesso a um imóvel específico, a uma faixa de horário comercial determinada ou a uma data de agendamento confirmada. Para reproduzir tais restrições no RBAC, o administrador seria obrigado a multiplicar papéis de forma insustentável (*role explosion*) (AMEER et al., 2022).

Portanto, evidencia-se a necessidade de adotar modelos mais expressivos, capazes de fundamentar decisões de autorização em dados contextuais em vez de relações binárias entre usuários e funções organizacionais.

2.2.2 Controle de Acesso Baseado em Atributos (ABAC) e o Modelo HABACα

O Controle de Acesso Baseado em Atributos (*Attribute-Based Access Control* – ABAC) supera as limitações do RBAC ao computar permissões a partir da avaliação dinâmica de atributos pertencentes a quatro categorias: sujeito (identidade do usuário, certificação do corretor), recurso (identificador do imóvel, estado da fechadura), ação pretendida (destravar, auditar) e ambiente (data, hora, geolocalização ou duração da visita) (AMEER et al., 2022; AUTHORS, 2022).

A flexibilidade do ABAC foi aprimorada por Ameer et al. (2022) na formulação do modelo HABACα (*Home Attribute-Based Access Control*), voltado ao ecossistema de residências inteligentes. O HABACα formaliza políticas de autorização sensíveis ao contexto que consideram a hierarquia espacial do imóvel e condicionantes temporais estritas. Sob o HABACα, a autorização deixa de ser uma permissão perpétua e torna-se um evento transitório, revogado no instante em que qualquer condição contextual (como o término do horário estipulado) for violada (AMEER et al., 2022).

Essa formulação conceitual é diretamente transposta para a arquitetura desta pesquisa: o corretor parceiro apenas obtém acesso ao imóvel se preencher concomitantemente o vínculo ativo com a imobiliária, o agendamento prévio cadastrado e a janela cronológica precisa da visita.

2.2.3 Autenticação Temporária por Tokens Efêmeros

Para que as políticas avaliadas pelo motor ABAC sejam executadas com agilidade na ponta sem sobrecarregar a fechadura, adota-se o paradigma de autenticação temporária desacoplada mediante tokens efêmeros (SATANASAOWAPAK; MANASATHIEN; TREEBUPACHATSAKUL, 2021). Sob essa abordagem, a infraestrutura central de autorização gera um código criptográfico temporizado dotado de tempo de vida útil reduzido (*Time-To-Live* – TTL), entregue digitalmente ao dispositivo do solicitante.

Satanasaowapak, Manasathien e Treebupachatsakul (2021) propuseram um sistema de fechadura inteligente baseado em tokens descartáveis e senhas temporárias (OTP), demonstrando que o uso de credenciais que expiram automaticamente anula o risco associado ao roubo, compartilhamento ou vazamento posterior de senhas estáticas. De modo complementar, Researchers (2022) ressaltam que tokens efêmeros permitem delegar ao cliente a comprovação de sua legitimidade com baixíssima complexidade de checagem no dispositivo de atuação.

Assim, a geração de tokens dinâmicos no artefato deste TCC garante que a chave digital permaneça válida estritamente pelo intervalo necessário para a vistoria do imóvel, impedindo reutilizações indevidas por corretores ou terceiros após o término do evento.

2.2.4 Criptografia Assimétrica e Verificação Offline em Dispositivos de Borda

A adoção de criptografia assimétrica baseada em curvas elípticas (ECC — *Elliptic Curve Cryptography*) representa uma solução computacionalmente viável para implementar autenticação robusta em microcontroladores restritos sem depender de conectividade de rede no momento do acesso (HAN et al., 2018). Ao contrário de protocolos simétricos que exigem o compartilhamento prévio de um segredo entre remetente e receptor, o modelo assimétrico separa claramente as responsabilidades: a chave privada, custodiada com exclusividade pelo servidor central, assina digitalmente o token de acesso durante a fase de agendamento online; a chave pública correspondente, gravada em memória não volátil do microcontrolador, executa apenas a verificação criptográfica dessa assinatura no momento do destravamento (HAN; DU; LU, 2020).

Essa dissociação atende diretamente ao cenário de imóveis desocupados sem infraestrutura de rede local: o dispositivo de borda não precisa consultar qualquer servidor para validar a autenticidade e a vigência da credencial. O processo de verificação de uma assinatura ECC é uma operação matemática de custo computacional reduzido e tempo constante, executável em centenas de milissegundos mesmo em processadores de baixo consumo energético. Han, Du e Lu (2020) validaram experimentalmente essa premissa ao construir um protótipo de fechadura inteligente offline com validação completa em apenas 339 milissegundos em um microcontrolador ARM Cortex-A7, demonstrando que a arquitetura de verificação local alia rigor de segurança à agilidade operacional para o usuário final.

A curva Ed25519, variante de assinatura de alta performance derivada da Curve25519,

destaca-se nesse contexto por oferecer chaves de apenas 32 bytes, assinaturas de 64 bytes e resistência comprovada a ataques de canal lateral, sendo implementada nativamente nas principais bibliotecas de criptografia embarcada (HAN et al., 2018). Esse conjunto de propriedades fundamenta a escolha do esquema de assinatura digital assimétrica como mecanismo central de autenticação offline no artefato proposto neste trabalho.

2.3 Fechaduras Inteligentes e Trabalhos Relacionados

2.3.1 Limitações dos Mecanismos Tradicionais de Acesso Físico

Os mecanismos tradicionais de controle de acesso a imóveis dependem prioritariamente de chaves metálicas mecânicas ou de cartões magnéticos e códigos numéricos estáticos (SATANASAOWAPAK; MANASATHIEN; TREEBUPACHATSAKUL, 2021; SILVA; SAMANIEGO; DETERS, 2023). No contexto operacional de imobiliárias que gerenciam dezenas ou centenas de propriedades distribuídas geograficamente, esse paradigma acarreta severas deficiências práticas.

Primeiramente, o manuseio de chaves físicas impõe sobrecarga logística, exigindo que corretores parceiros desloquem-se até a sede da empresa apenas para retirar e devolver os chaveiros, além de expor os proprietários ao risco de clonagem clandestina de lâminas metálicas sem qualquer vestígio (SATANASAOWAPAK; MANASATHIEN; TREEBUPACHATSAKUL, 2021). Em segundo lugar, senhas estáticas compartilhadas por mensagens informais tendem a ser repassadas entre corretores e prestadores de serviços, tornando impossível assegurar quem de fato acessou o recinto (SILVA; SAMANIEGO; DETERS, 2023). Finalmente, tais métodos não produzem registros automatizados de entrada e saída, impedindo auditorias eficientes caso ocorram furtos ou danos aos imóveis.

O Quadro 1 sintetiza as principais características e fragilidades desses métodos frente aos requisitos demandados pelo cenário investigado e pelo artefato proposto.

2.3.2 Sistemas de Fechaduras Baseados em IoT

A substituição de cilindros mecânicos por fechaduras inteligentes conectadas (*smart locks*) transforma o ponto de acesso em um nó computacional autônomo. O acionamento da tranca passa a ser intermediado por sinais eletrônicos condicionados à verificação de credenciais digitais móveis, biometria facial ou leitura de códigos bidimensionais (QR Codes) (SATANASAOWAPAK; MANASATHIEN; TREEBUPACHATSAKUL, 2021; AUTHORS, 2025).

Diversos projetos acadêmicos e comerciais vêm aplicando essa transição. Authors (2025) utilizam visão computacional embarcada para identificação facial em fechaduras inteligentes residenciais. Contudo, conforme apontado por Authors (2024), abordagens dependentes exclusivamente de hardware biométrico local aumentam exponencialmente o custo unitário por porta, além de criarem barreiras de privacidade e exigirem o cadastramento facial prévio de

Tabela 1 – Comparação entre métodos convencionais de controle de acesso e o artefato proposto.

Método	**Rastreabilidade**	**Revogação**	**Modo Offline**	**Limitação Principal**
Chave física metálica	Não	Não	Sim	Risco de cópia ou extravio não registrado (SILVA; SAMANIEGO; DETERS, 2023).
Cofre mecânico com segredo (*lockbox*)	Não	Não	Sim	Senhas estáticas repassadas informalmente entre dezenas de corretores.
Teclado numérico local (*PIN pad*)	Não	Parcial	Sim	Vulnerável à observação de terceiros (*shoulder surfing*) e ataques de força bruta (AUTHORS, 2024).
Fechadura inteligente comercial (Wi-Fi)	Sim	Sim	Não	Depende de conexão fixa local com servidores do fabricante (VARDAKIS et al., 2024).
Artefato proposto (DSR)	**Sim**	**Sim**	**Sim**	**Validação por chave pública e delegação por token com TTL.**

Fonte: Elaborado pelo autor (2026).

todos os corretores parceiros em cada dispositivo instalado. Por sua vez, fechaduras comerciais dependentes de nuvens proprietárias expõem o administrador ao confinamento tecnológico (*vendor lock-in*) e a custos contínuos de assinatura (SILVA; SAMANIEGO; DETERS, 2023).

Nesse cenário, dois trabalhos acadêmicos se destacam pela abordagem pioneira de autenticação offline em fechaduras inteligentes. Han et al. (2018) propuseram o BC-SNOA (*Blockchain-based Succinct Non-interactive Offline Authentication*), um esquema que combina criptografia de curva elíptica (ECC — Secp256k1), Prova de Trabalho (PoW) baseada em SHA-256 e provas de conhecimento zero (zk-SNARKs) para permitir que a fechadura valide o QR Code apresentado pelo usuário de forma completamente offline, sem consultar qualquer servidor ou nuvem no momento do destravamento. O token é gerado durante a fase de reserva online e encapsulado em um código QR entregue ao smartphone do usuário; na porta, a fechadura executa a verificação matemática local e aciona o mecanismo de abertura sem qualquer dependência de conectividade.

Han, Du e Lu (2020) avançaram sobre essa proposta com o esquema OTMP-P2L (*One-Time Association Multitask Proofs for Peer to Local Authentication*), estruturado em torno de provas de conhecimento zero encadeadas baseadas em problemas NP: prova de período temporal (ECC homomórfico), prova de token legítimo (HMAC e assinatura ECC), prova de trabalho (PoW SHA-256) e verificação de pertencimento ao grupo por meio do acumulador unidirecional de Nyberg. Em testes físicos com microcontrolador ARM Cortex-A7 e leitor de QR Code, os autores alcançaram tempo de validação completa de apenas 339 milissegundos e tamanho de token de 593 bytes — resultados que demonstram a plena viabilidade da abordagem em hardware restrito de baixo custo.

2.3.3 Análise Comparativa do Estado da Arte

Para fundamentar as escolhas arquiteturais e demonstrar a lacuna tecnológica atendida por esta pesquisa, o Quadro 2 sintetiza a comparação crítica entre as principais soluções identificadas na literatura recente frente à proposta deste trabalho.

Tabela 2 – Comparação entre soluções da literatura e a arquitetura proposta.

Trabalho / Autor	**Mecanismo**	**Protocolo**	**Controle / Aut.**	**Lacuna Identificada**
Satanasaowapak, Manasathien e Treebupachatsakul (2021)	OTP / Token Web	HTTP / Web Server	Estático temporizado	Dependência de servidor web local; sem suporte ABAC contextual.
Ameer et al. (2022) (HABACα)	Atributos / App	MQTT / TLS	ABAC formal hierárquico	Focado em residências unifamiliares; não aborda terceirização ou múltiplos parceiros.
Vardakis et al. (2024)	Gateway Smart Home	Não especificado	Baseado em papéis	Abordagem genérica de segurança; ausência de protótipo de acesso físico.
Silva, Samaniego e Deters (2023)	Smart Contracts / IoT	Blockchain	Descentralizado / P2P	Alta sobrecarga computacional e latência de mineração; inviável em cenários de baixo custo.
Authors (2024)	Biometria / Senha	Wi-Fi / Cloud	Autenticação local	Custo elevado por nó; vulnerável ao compartilhamento presencial de senhas.
Authors (2025)	Visão (YOLOv5)	Rede local	Reconhecimento Facial	Alto consumo de processamento; exige pré-cadastro de faces para cada corretor.
Han et al. (2018) (BCSNOA)	ECC + PoW + zk-SNARK + QR Code	Nenhum (offline)	Criptográfico offline	Contexto de reserva de salas corporativas; sem ABAC imobiliário; sem ESP32.
Han, Du e Lu (2020) (OTMP-P2L)	ECC + PoW + HMAC + Acumulador Nyberg	Nenhum (offline)	Provas NP encadeadas	Prova de conceito em ARM; sem rastreabilidade de auditoria; sem contexto imobiliário.
Artefato Proposto	**Token Ed25519 / ABAC**	**QR Code Offline**	**ABAC Contextual Offline**	**Baixo custo, validação 100% offline sem Wi-Fi no imóvel, múltiplos parceiros e trilha completa de auditoria.**

Fonte: Elaborado pelo autor (2026).

A comparação evidenciada no Quadro 2 ratifica que, conquanto existam iniciativas sofisticadas baseadas em blockchain (SILVA; SAMANIEGO; DETERS, 2023) ou visão computacional (AUTHORS, 2025), persiste uma carência de arquiteturas enxutas que combinem baixo custo de implantação, autorização contextual dinâmica (ABAC) e auditoria transparente para ambientes

corporativos com múltiplos atores externos.

2.4 Segurança, Rastreabilidade e Auditoria em Sistemas IoT

2.4.1 Vetores de Ataque e Vulnerabilidades Comuns

No modelo proposto, três vetores de ataque são especialmente críticos: a interceptação do token em trânsito, a reutilização de um QR Code já utilizado e o uso indevido do smartphone do corretor como ponto de decisão de segurança (AUTHORS, 2024; RESEARCHERS, 2021). A espionagem passiva (*eavesdropping*), os ataques de repetição (*replay attacks*) e a interceptação ativa (*man-in-the-middle*) são os mecanismos concretos associados a esses vetores (AUTHORS, 2024). A ausência de criptografia de transporte no MQTT permitiria que um invasor capturasse o comando de abertura e o replicasse para destrancar o imóvel em momento posterior.

Em cenários de validação offline, o risco de reutilização de tokens persiste mesmo sem acesso à rede: um atacante que capture o QR Code durante uma visita pode tentar apresentá-lo novamente após o encerramento da janela temporal autorizada. Para neutralizar essa ameaça, o artefato proposto associa a cada token um identificador único de uso único (*nonce* — campo `jti` do JWT), cujo registro é persistido em buffer circular na memória não volátil (NVS Flash) do microcontrolador, garantindo que nenhum token já processado seja aceito novamente, independentemente de sua validade criptográfica (HAN; DU; LU, 2020).

Adicionalmente, Zhou et al. (2022) mapearam sistematicamente as vulnerabilidades introduzidas pelo paradigma *Mobile-as-a-Gateway* (MaaG), no qual o smartphone do usuário atua não como simples transportador, mas como árbitro ativo das políticas de acesso. Os autores identificaram quatro classes críticas de falha — perda semântica na tradução de permissões, responsabilidades assimétricas entre nuvem e dispositivo, inconsistência causal na sincronização e injeção de chaves ocultas locais — que permitem a usuários temporários manter acesso indefinido ao dispositivo físico mesmo após revogação no servidor. Esse diagnóstico fundamenta uma decisão arquitetural central no presente trabalho: o smartphone do corretor atua exclusivamente como transportador passivo do token assinado, sem poder de decisão ou armazenamento de regras de acesso; toda a lógica de validação reside no microcontrolador.

No plano das credenciais, o emprego de senhas estáticas ou padrões PIN perpetua vulnerabilidades de força bruta e captura por engenharia social (AUTHORS, 2024). Paralelamente, como advertem Silva, Samaniego e Deters (2023), a dependência irrestrita de serviços em nuvem proprietários de terceiros introduz o perigo de exfiltração não controlada de registros de acesso ou de indisponibilidade unilateral dos servidores remotos durante vistorias essenciais.

2.4.2 Mecanismos de Proteção e Trilhas de Auditoria

Para mitigar integralmente as fragilidades delineadas, a arquitetura do artefato adota uma estratégia de defesa em profundidade estruturada em quatro pilares técnicos complementares:

1. **Criptografia de Transporte (TLS):** Blindagem criptográfica fim a fim de todos os pacotes MQTT trafegados entre os clientes, o broker e o microcontrolador, inviabilizando técnicas de leitura e injeção maliciosa de pacotes (AMEER et al., 2022; AUTHORS, 2024).

2. **Descarte Temporal de Credenciais:** Configuração de expiração algorítmica estrita (TTL curto) associada a cada token gerado, eliminando os impactos de vazamento de credenciais pós-uso (SATANASAOWAPAK; MANASATHIEN; TREEBUPACHATSAKUL, 2021).

3. **Isolamento em Gateway Local:** Centralização da tomada de decisão no gateway de borda, preservando a fechadura contra conexões diretas oriundas da internet pública (VARDAKIS et al., 2024; AMEER et al., 2022).

4. **Trilha Auditável de Eventos (*Audit Trail*):** Persistência sequencial imutável de todos os eventos de autorização, abrangendo concessões legítimas, recusas de tentativas fora do expediente e revogações forçadas de acesso (AUTHORS, 2024).

A consolidação de logs auditáveis atende com rigor à necessidade de transparência demandada pela governança imobiliária: a qualquer instante, a administração dispõe de comprovação cabal de qual corretor solicitou a entrada, o instante exato de liberação e o tempo decorrido até o trancamento, estabelecendo a responsabilização inequívoca pelo patrimônio administrado.

Dessa forma, o conjunto de conceitos, protocolos e modelos analíticos delineados neste capítulo fornece o embasamento teórico e a justificativa técnica necessários para a formalização metodológica e o desenvolvimento do protótipo simulado nos capítulos subsequentes.

3 Metodologia e Desenvolvimento do Artefato

Este capítulo detalha a metodologia de pesquisa empregada no trabalho e a especificação técnica do artefato desenvolvido. O projeto fundamenta-se nas diretrizes da *Design Science Research* (DSR), orientando-se pela construção e avaliação sistemática de uma solução para o problema de controle de acesso a imóveis desocupados sem conectividade local.

A estrutura do capítulo divide-se em dez seções: a caracterização metodológica e o mapeamento das etapas do DSR; a contextualização e formalização do problema prático; a visão arquitetural em camadas; o modelo formal de autorização baseado em atributos (ABAC); o esquema criptográfico assimétrico para validação offline; o fluxo de ponta a ponta do sistema; a especificação da pilha tecnológica e do firmware; o ambiente de simulação virtual no Wokwi; os cenários de demonstração funcional; e o conjunto de métricas quantitativas adotadas para a avaliação experimental.

3.1 Caracterização Metodológica

3.1.1 Design Science Research como Paradigma de Pesquisa

A pesquisa científica em computação tradicionalmente divide-se entre abordagens explicativas ou descritivas (ciências naturais e comportamentais) e abordagens prescritivas ou de projeto (ciências do artificial). Enquanto as primeiras dedicam-se a observar, compreender e explicar fenômenos existentes, a *Design Science Research* (DSR) foca na criação de artefatos tecnológicos projetados para solucionar problemas humanos e organizacionais concretos (HEVNER et al., 2004).

De acordo com Hevner et al. (2004), a DSR combina rigor científico com relevância prática. O rigor manifesta-se no emprego de teorias fundamentadas, métodos consolidados de engenharia e procedimentos formais de avaliação extraídos da base de conhecimento existente. A relevância decorre da aplicabilidade direta da solução aos problemas enfrentados pelos atores no ambiente real de negócios.

Neste trabalho, o problema investigado decorre de limitações operacionais e brechas de segurança observadas na rotina de imobiliárias e corretores autônomos. A pesquisa prescinde de caráter puramente exploratório ou teórico; exige a concepção, implementação e validação empírica de um artefato funcional composto por modelos conceituais, protocolos criptográficos, firmware embarcado e infraestrutura de mensageria. A DSR fornece a estrutura formal necessária para estruturar esse processo construtivo e iterativo.

3.1.2 Mapeamento das Fases do DSR no Trabalho

O desenvolvimento do artefato segue o modelo de processo proposto por Peffers et al. (2007), composto por seis etapas sequenciais com suporte a ciclos de refinamento iterativo. O Quadro 3 detalha a correspondência entre cada fase conceitual e as atividades executadas no escopo desta pesquisa.

Tabela 3 – Mapeamento das etapas da Design Science Research ao projeto.

Fase	**Etapa Conceitual (PEFFERS et al., 2007)**	**Materialização no Trabalho**	**Localização**
1	Identificação do Problema e Motivação	Mapeamento das falhas dos métodos físicos (chaves, cofres e senhas estáticas) em imóveis desocupados sem conexão à internet.	Seção 3.2
2	Definição dos Objetivos da Solução	Definição dos requisitos funcionais, não funcionais e objetivos específicos (modelagem ABAC, protótipo funcional e avaliação empírica).	Seção 3.2.4 e Cap. 1
3	Concepção e Desenvolvimento do Artefato	Modelagem formal da arquitetura HABACα, implementação do esquema criptográfico Ed25519, codificação do firmware ESP32 e API FastAPI.	Seções 3.3 a 3.8
4	Demonstração	Execução dos três cenários funcionais (concessão válida, rejeição de acessos anômalos e revogação emergencial) em bancada virtual.	Seção 3.9
5	Avaliação	Coleta e análise estatística de oito métricas quantitativas de desempenho temporal, memória e integridade de bloqueio.	Seção 3.10 e Cap. 4
6	Comunicação	Redação da monografia de TCC, produção de diagramas técnicos e disseminação dos resultados obtidos.	Monografia completa

Fonte: Elaborado pelo autor (2026).

A DSR prevê retornos iterativos entre as fases de avaliação e desenvolvimento. Desvios nas métricas de latência ou sobrecarga de memória identificados durante os ensaios de demonstração demandam ajustes na codificação do firmware ou na estrutura do payload de dados antes da consolidação final dos resultados.

3.2 Contexto e Formalização do Problema

3.2.1 O Cenário de Gestão de Visitas em Imóveis Desocupados

No setor imobiliário, a comercialização e a locação de unidades habitacionais e comerciais apoiam-se na atuação de corretores parceiros e profissionais externos. Esses agentes realizam atendimentos a potenciais compradores, vistorias técnicas, serviços de manutenção predial e registros fotográficos.

Ao contrário de residências habitadas, onde residem moradores capazes de franquear a entrada ou onde existe conexão de banda larga ativa, as unidades vagas apresentam características operacionais específicas:

1. **Inexistência de rede de dados local:** Imobiliárias e proprietários não contratam planos de internet fixa para imóveis desocupados em virtude do custo financeiro desnecessário durante o período de vacância.
2. **Ausência de supervisão física:** Não há recepcionistas, porteiros ou moradores permanentes para fiscalizar a entrada ou monitorar a permanência no interior da propriedade.
3. **Pluralidade e rotatividade de atores:** Profissionais autônomos vinculados a diferentes imobiliárias parceiras necessitam de permissões dinâmicas de acesso, com janelas temporais curtas e sobrepostas.

3.2.2 Análise Crítica dos Métodos Convencionais no Contexto do Problema

Os métodos comumente aplicados pelo mercado para franquear o acesso de corretores a unidades desocupadas revelam deficiências operacionais e de segurança, conforme sintetizado no Quadro 1 (Seção 2.3.1).

Sob a ótica da primeira etapa do DSR (identificação e motivação do problema), essas limitações evidenciam que, embora as fechaduras conectadas comerciais resolvam a rastreabilidade e a revogação instantânea, elas dependem de conexão Wi-Fi contínua na residência. Em imóveis desprovidos de rede, tais equipamentos tornam-se inoperantes ou dependem de chaves metálicas mecânicas, anulando os benefícios digitais pretendidos e justificando o desenvolvimento do artefato proposto.

3.2.3 Definição do Problema e Questão de Pesquisa

A incapacidade dos mecanismos atuais de aliar operação desconectada, validação criptográfica pontual e auditoria confiável motiva a questão central de pesquisa formulada para este trabalho:

> *Como projetar e avaliar uma arquitetura de controle de acesso inteligente baseada em IoT capaz de gerenciar, de forma segura, rastreável e orientada a atributos (ABAC), o acesso temporário de múltiplos corretores parceiros a imóveis desocupados desprovidos de conexão à internet?*

3.2.4 Requisitos e Pilares de Concepção do Artefato

Para resolver o problema formulado, o artefato estrutura-se sobre quatro pilares técnicos mandatórios:

1. **Independência de infraestrutura local de rede (*Zero Local Infrastructure*):** O nó eletrônico embarcado na porta do imóvel deve validar a credencial de acesso e acionar a trava eletromecânica sem consultar servidores remotos no instante do acionamento e sem exigir modems ou chips celulares (SIM/M2M) dedicados na placa.

2. **Autenticidade e não-repúdio da delegação:** A credencial deve ser pessoal, intransferível e vinculada ao smartphone cadastrado do corretor, impedindo o repasse de permissões a terceiros.

3. **Autorização granular por atributos contextuais (ABAC):** A permissão deve ser concedida mediante avaliação de condições lógicas estritas (horário comercial, situação cadastral do corretor, status do imóvel e existência de vistoria agendada).

4. **Rastreabilidade e sincronização assíncrona de eventos:** Todo acionamento ou tentativa frustrada de acesso deve gerar registros invioláveis de auditoria, sincronizados com a nuvem por meio do smartphone do usuário.

3.3 Arquitetura Geral do Artefato

3.3.1 Visão em Camadas do Ecossistema IoT

Em conformidade com a taxonomia de sistemas IoT apresentada por Vardakis et al. (2024), a arquitetura divide-se em quatro camadas funcionais e físicas delimitadas:

1. **Camada de Aplicação e Gestão:** Hospeda o painel administrativo da imobiliária (configuração de políticas e cadastro) e o aplicativo móvel do corretor (solicitação de acesso e recepção de credenciais).

2. **Camada de Serviço e Decisão:** Executada em ambiente de computação em nuvem, centraliza o motor de inferência ABAC(Controle de Acesso Baseado em Atributos), o módulo de assinatura criptográfica e o *broker* de mensageria para ingestão de eventos.

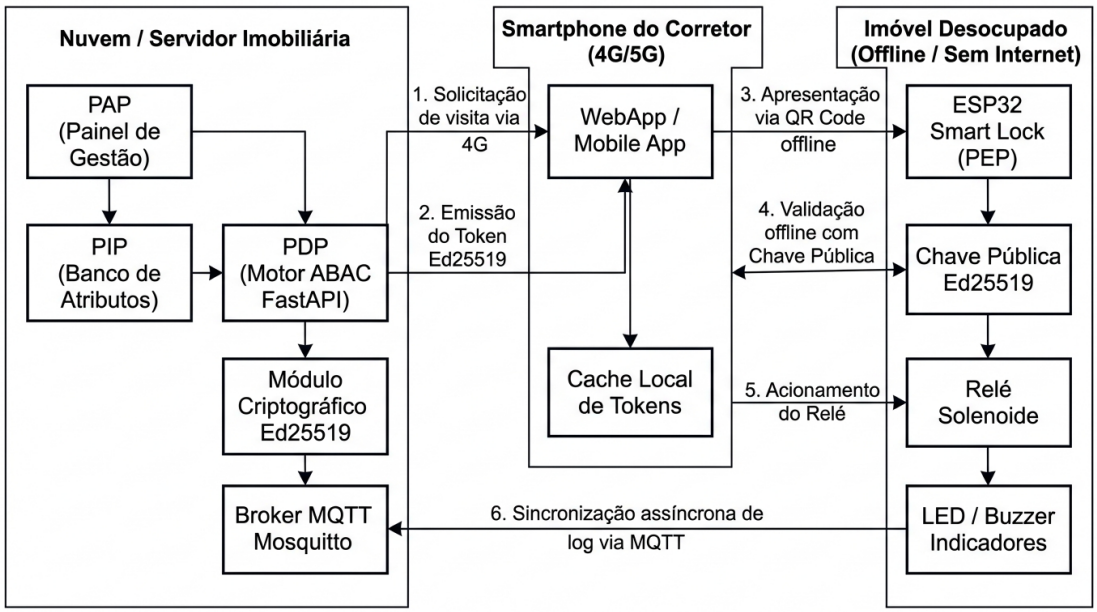
3. **Camada de Rede e Transporte:** Abrange os protocolos de comunicação do sistema, compreendendo conexões celulares 4G/5G (HTTPS/REST) entre o aplicativo e a nuvem, o canal desconectado por leitura óptica (QR Code) entre smartphone e fechadura, e o protocolo MQTT(Protocolo de Mensageria Leve) com entrega garantida (QoS 1) para telemetria.

4. **Camada Física e de Percepção:** Reúne o microcontrolador ESP32 instalado na porta do imóvel, o relé que comanda a trava solenoide, os sinais de retorno ao usuário (LED e *buzzer*) e o leitor responsável por capturar o payload do QR Code.

3.3.2 Componentes Arquiteturais e Responsabilidades

A Figura 1 ilustra a topologia do sistema, evidenciando o desacoplamento entre a infraestrutura central de decisão e a unidade de execução local na porta do imóvel.

Figura 1 – Visão geral da arquitetura do artefato IoT em ambiente desconectado.



Fonte: Elaborado pelo autor (2026).

O ecossistema divide-se em três domínios físicos com responsabilidades bem delimitadas:

- **Nuvem da Imobiliária:** Centraliza os serviços corporativos e a tomada de decisão. Abriga o Painel de Gestão (*Policy Administration Point* – PAP), o banco de atributos cadastrais (*Policy Information Point* – PIP), o motor de regras (*Policy Decision Point* – PDP em FastAPI), o módulo criptográfico detentor da chave privada Ed25519 e o broker de mensageria MQTT (Eclipse Mosquitto) para recepção das telemetrias de auditoria.
- **Smartphone do Corretor:** Atua como elemento intermediário e portador (*data mule/carrier*) de credenciais e telemetrias. Como o corretor dispõe de franquia de dados celulares (4G/5G), seu smartphone estabelece a ponte de comunicação entre a nuvem e o imóvel desocupado, requisitando o token pela internet e apresentando-o localmente por leitura óptica.
- **Nó da Fechadura (ESP32):** Atua como Ponto de Execução de Políticas (*Policy Enforcement Point* – PEP) local. Opera em regime estritamente desconectado (*zero local infrastructure*), desprovido de conexão Wi-Fi ou modem celular. Armazena exclusivamente a chave pública da autoridade emissora em memória permanente protegida, garantindo que mesmo o furto do hardware não exponha segredos criptográficos capazes de forjar acessos.

A interação entre os três domínios cumpre um ciclo operacional composto por seis etapas numeradas:

1. **Solicitação de visita via canal celular (4G/5G):** Ao se aproximar do imóvel, o corretor aciona o aplicativo móvel, que despacha uma requisição HTTPS ao PDP na nuvem informando seu identificador, o imóvel de interesse e os dados de contexto da visita.

2. **Avaliação de políticas e emissão do token assinado:** O PDP interroga a base relacional (PIP) para confrontar a situação do corretor e o agendamento ativo. Aprovadas as regras ABAC, o módulo criptográfico gera o payload com identificador exclusivo (`jti`) e assina digitalmente os dados com a chave privada mestre Ed25519, devolvendo a credencial ao aplicativo móvel, que a retém em cache seguro.

3. **Apresentação da credencial via QR Code offline:** O smartphone renderiza a credencial serializada na forma de código QR óptico na tela do aparelho. O corretor aproxima o display do leitor conectado ao ESP32. Esse canal óptico unidirecional não requer nenhum tipo de pareamento de rede local (como Wi-Fi ou Bluetooth).

4. **Validação criptográfica determinística offline:** O microcontrolador ESP32 processa os dados do payload e recalcula a assinatura digital contra a chave pública mestre gravada em seu firmware. Em seguida, verifica o código do dispositivo de destino (`dev`), confere a vigência temporal (`nbf` e `exp`) e consulta o buffer anti-replay mantido na partição NVS.

5. **Atuação física na fechadura e feedback sensorial:** Uma vez satisfeitas todas as condições criptográficas e temporais, o firmware envia um nível lógico alto ao pino GPIO 23, excitando a bobina do relé por 5 segundos para retrair o solenoide da trava. Simultaneamente, o LED verde pisca e o *buzzer* emite um sinal sonoro simples de confirmação.

6. **Sincronização assíncrona de auditoria via MQTT:** Por se tratar de um imóvel desocupado sem infraestrutura de rede, o microcontrolador da fechadura não possui enlace de dados para dialogar diretamente com a nuvem. A sincronização da trilha de auditoria é transferida ao smartphone do corretor, que utiliza sua conexão celular 4G/5G para despachar um pacote de confirmação contendo o identificador `jti` ao broker MQTT corporativo (canal `imobiliaria/auditoria/acessos`) sob o protocolo QoS 1 (*at least once*). O serviço em nuvem registra o timestamp e a efetivação da entrada na base imobiliária, garantindo a rastreabilidade integral da operação sem violar o isolamento do nó físico.

3.4 Modelo de Autorização Baseado em Atributos (ABAC)

3.4.1 Fundamentação: Do RBAC ao ABAC

O modelo de Controle de Acesso Baseado em Papéis (*Role-Based Access Control* – RBAC) define privilégios a partir de funções estáticas de usuários. No cenário de intermediação imobiliária, o RBAC demonstra insuficiência: determinar apenas se um usuário possui o papel de "corretor" não impede que ele ingresse no imóvel fora do horário comercial, acesse unidades sob reforma ou entre em propriedades que não possui agendamento atribuído.

O Controle de Acesso Baseado em Atributos (*Attribute-Based Access Control* – ABAC), adaptado da arquitetura HABACα proposta por Ameer et al. (2022), resolve essa limitação avaliando regras compostas por múltiplos atributos dinâmicos em tempo de execução:

$$\text{Decisão} = f(U_{\text{atrib}},\ D_{\text{atrib}},\ OP_{\text{atrib}},\ ES_{\text{atrib}}) \tag{3.1}$$

Em que U_{atrib} representa os atributos do sujeito solicitante, D_{atrib} os atributos do dispositivo/imóvel de destino, OP_{atrib} os parâmetros da ação requerida e ES_{atrib} as variáveis contextuais do ambiente no instante da avaliação.

3.4.2 Entidades e Dicionário de Atributos do Sistema

O modelo computacional implementado categoriza treze atributos fundamentais para a regulação do acesso às unidades, dispostos no Quadro 4.

3.4.3 Arquitetura Funcional segundo o Padrão NIST SP 800-162

A segregação funcional dos módulos de controle de acesso adota as especificações do padrão NIST SP 800-162, dividindo os papéis de administração, armazenamento, decisão e aplicação, conforme detalhado na Figura 2.

A cooperação entre os componentes ocorre da seguinte maneira:

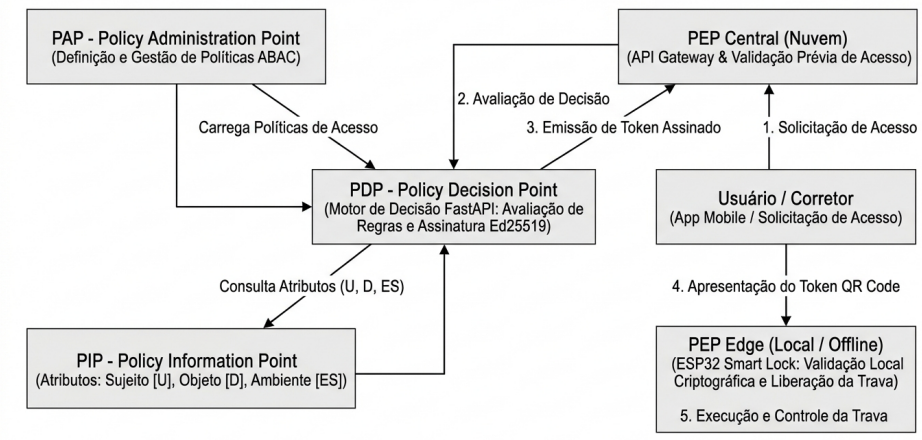
- **PAP** (*Policy Administration Point*): Interface web administrativa em que gestores imobiliários definem e alteram políticas de acesso de corretores e horários de visitação dos imóveis.
- **PIP** (*Policy Information Point*): Banco de dados estruturado que fornece os valores reais dos atributos associados ao corretor, ao imóvel e ao agendamento.
- **PDP** (*Policy Decision Point*): Motor de avaliação lógico construído em FastAPI/Python. Processa a requisição, recupera atributos do PIP, avalia a política vigente e, caso aprovada, invoca o módulo criptográfico para emissão do token assinado.
- **PEP Central** (*Cloud PEP*): Ponto de aplicação de borda de nuvem no API Gateway, responsável por barrar chamadas malformadas ou de usuários não autenticados.

Tabela 4 – Dicionário de atributos do modelo ABAC implementado.

Entidade	Símbolo	Atributo	Definição e Tipagem
Sujeito (U)	U	`u.id`	String (UUID): Identificador único do corretor.
	U	`u.role`	Enum: `CORRETOR_PARCEIRO`, `GESTOR`.
	U	`u.status`	Enum: `ATIVO`, `SUSPENSO`, `PENDENTE`.
	U	`u.device_fp`	String (Hash SHA-256): Identificador do aparelho móvel cadastrado.
Objeto (D)	D	`d.lock_id`	String (Hex): Identificador físico gravado no ESP32 (MAC/UUID).
	D	`d.status_imovel`	Enum: `DISPONIVEL_VENDA`, `LOCADO`, `MANUTENCAO`.
	D	`d.lock_state`	Enum: `TRAVADO`, `DESTRAVADO`, `BLOQUEIO`.
Ação (OP)	OP	`op.tipo`	Enum: `SOLICITAR_TOKEN`, `DESTRAVAR_PORTA`.
	OP	`op.modo`	Enum: `OFFLINE_BEARER`, `TELEMETRIA`.
Ambiente (ES)	ES	`es.timestamp`	Inteiro (Unix Epoch): Horário de recepção da solicitação.
	ES	`es.horario_comercial`	Booleano: `true` se horário atual estiver entre 08h e 19h.
	ES	`es.dia_permitido`	Booleano: Restrição a finais de semana ou feriados.
	ES	`es.agendamento_ativo`	Booleano: Confirmação de visita agendada na base imobiliária.

Fonte: Elaborado pelo autor (2026).

Figura 2 – Arquitetura funcional de controle de acesso ABAC baseada no padrão NIST SP 800-162.



Fonte: Elaborado pelo autor (2026).

- **PEP Borda** (*Edge PEP*): Firmware embarcado no microcontrolador ESP32 na porta do imóvel. Recebe o token, verifica a assinatura digital contra a chave pública da autoridade e executa o chaveamento do relé.

3.4.4 Formalização das Regras de Acesso e Algoritmo de Decisão

As regras de acesso são definidas em esquemas JSON avaliados pelo PDP central. O Código 3.1 ilustra a política principal que regula as solicitações de visita para imóveis ofertados.

Listing 3.1 – Estrutura da política de autorização ABAC para visitas imobiliárias.

```
{
  "policy_id": "POL_VISITA_IMOVEL_DISPONIVEL",
  "description": "Permite visita de corretores ativos a imoveis disponiveis em
      horario comercial",
  "target": {
    "action": "SOLICITAR_TOKEN",
    "role": "CORRETOR_PARCEIRO"
  },
  "rules": [
    {
      "rule_id": "REGRA_01_STATUS_CORRETOR",
      "condition": "u.status == 'ATIVO'",
      "effect": "Permit"
    },
    {
      "rule_id": "REGRA_02_STATUS_IMOVEL",
      "condition": "d.status_imovel in ['DISPONIVEL_VENDA', 'DISPONIVEL_LOCACAO']",
      "effect": "Permit"
    },
    {
      "rule_id": "REGRA_03_JANELA_HORARIA",
      "condition": "es.horario_comercial == true and es.dia_permitido == true",
      "effect": "Permit"
    },
    {
      "rule_id": "REGRA_04_VINCULO_AGENDAMENTO",
      "condition": "es.agendamento_ativo == true",
      "effect": "Permit"
    }
  ],
  "rule_combining_algorithm": "deny_overrides"
}
```

O algoritmo de combinação adotado é o `deny_overrides`. Sob essa disciplina, caso qualquer condição estipulada em uma regra resulte em negação (*Deny*), a requisição é indeferida pelo PDP, garantindo a aplicação do princípio do menor privilégio (*least privilege*).

3.5 Modelo Criptográfico e Validação Offline

3.5.1 O Princípio da Validação Desconectada (Analogia EMV)

O nó IoT instalado na porta do imóvel não dispõe de conexão com a internet para consultar o banco de dados da imobiliária no momento em que o corretor se apresenta no local. A solução deste desafio fundamenta-se no princípio adotado pelo padrão bancário internacional EMV (*Europay, Mastercard, Visa*) para transações em terminais de ponto de venda desconectados (*offline transaction verification*).

No padrão EMV offline, o terminal de pagamento desconhece previamente o saldo bancário da conta, mas possui internamente a chave pública da autoridade bancária emissora. Ao verificar a assinatura digital gravada no microprocessador do cartão com chip, o terminal obtém certeza matemática de que a credencial foi emitida por uma autoridade legítima e que os dados de transação permanecem inalterados.

No artefato desenvolvido, o servidor de políticas atua como a autoridade emissora (Banco), detentora exclusiva da chave privada mestre. O smartphone do corretor funciona como portador do token assinado. O nó ESP32 atua de forma homóloga ao terminal bancário: através da chave pública previamente instalada em sua memória, o microcontrolador autentica o token apresentado localmente, sem comunicação de rede externa.

3.5.2 Seleção Criptográfica: Justificativa do Algoritmo Ed25519

Microcontroladores de baixo consumo energético e dimensões reduzidas operam com severas limitações de memória volátil e capacidade de cálculo aritmético. Mecanismos assimétricos tradicionais, como RSA com chaves de 2048 ou 4096 bits, exigem operações intensivas de exponenciação modular, demandando elevado tempo de resposta e consumo excessivo de memória RAM.

A criptografia baseada em curvas elípticas contorna essa restrição. O algoritmo selecionado para o projeto é o Ed25519 (*Edwards-curve Digital Signature Algorithm*), baseado na Curva de Edwards Torcida Curve25519. O Quadro 5 compara as características técnicas de esquemas comuns frente às demandas do nó embarcado.

A adoção do Ed25519 confere uma vantagem de segurança estrutural: como o microcontrolador armazena exclusivamente a chave pública do sistema (32 bytes), mesmo na hipótese de um invasor subtrair o equipamento físico da porta e extrair todo o conteúdo da memória flash, ele não obtém a chave privada. Torna-se matematicamente impossível para o atacante forjar credenciais para ingressar em outras fechaduras do condomínio ou da imobiliária.

3.5.3 Estrutura do Token de Acesso

O token emitido pelo PDP e entregue ao corretor é compactado em formato serializado JSON ou CBOR. O Código 3.2 expõe a estrutura formal dos campos transmitidos.

Tabela 5 – Comparativo entre esquemas criptográficos para validação em nós IoT embarcados.

Critério	**RSA-2048**	**HMAC-SHA256**	**Ed25519**	**Impacto no ESP32**
Tipo de Chave	Assimétrica	Simétrica	Assimétrica	Protege contra cópia física da memória Flash.
Tamanho da Chave	256 bytes	32 bytes (segredo)	32 bytes	Reduzida ocupação em memória permanente.
Tamanho da Assinatura	256 bytes	32 bytes	64 bytes	Otimizado para pacotes seriais e códigos QR.
Tempo de Verificação	150 a 300 ms	< 1 ms	1,8 a 3,5 ms	Desempenho quase instantâneo de abertura.
Nível de Segurança	112 bits	128 bits	128 bits	Criptograficamente equivalente a RSA de 3072 bits.
Ataques de Canal Lateral	Moderada	Boa	Excelente	Imunidade a variações de tempo computacional.

Fonte: Elaborado pelo autor com base em Ameer et al. (2022) e dados experimentais (2026).

Listing 3.2 – Estrutura formal do payload do token de acesso emitido pelo PDP.

```
{
  "jti": "a7f4b892-91c2-4e88-9d21-f09b578c92a1",
  "sub": "corretor_id_8472",
  "dev": "lock_esp32_imovel_042",
  "nbf": 1774204800,
  "exp": 1774205700,
  "act": "UNLOCK_DOOR",
  "fp": "e3b0c442...[hash SHA-256 do aparelho]...",
  "sig": "3a8f9c10...[64 bytes assinatura Ed25519]..."
}
```

O detalhamento funcional de cada parâmetro constituinte consta no Quadro 6.

Tabela 6 – Dicionário de campos constituintes do token de acesso.

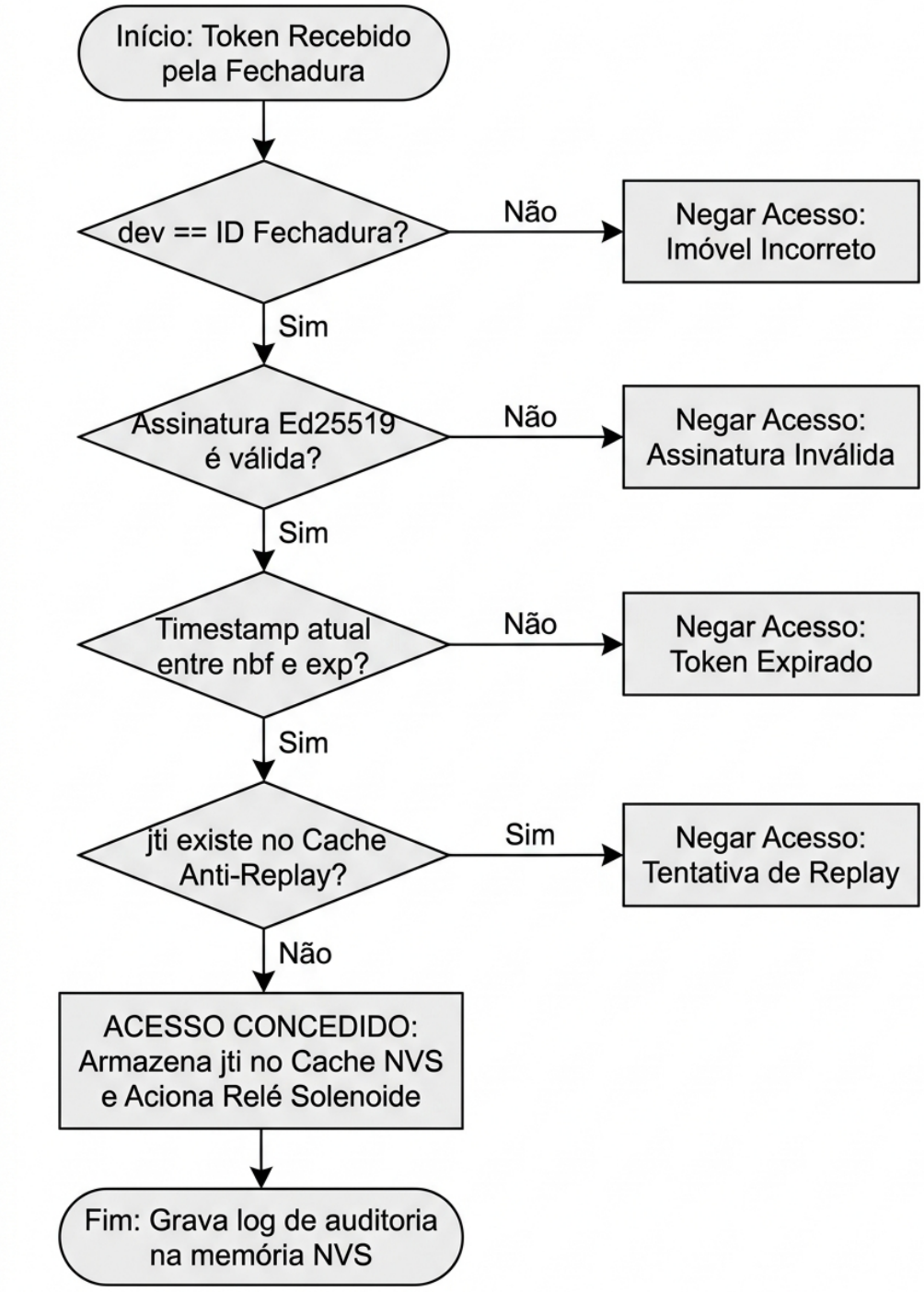
Campo	**Nome Técnico**	**Finalidade Funcional**
`jti`	JWT ID / Nonce	Identificador universal único (UUIDv4) para prevenção de ataques de repetição (*replay attack*).
`sub`	*Subject*	Identificador cadastral do corretor requerente habilitado.
`dev`	*Device Target*	Identificador exclusivo da fechadura destinatária. Evita o uso do token em portas incorretas.
`nbf`	*Not Before*	Timestamp Unix inicial que estabelece o início da validade da permissão concedida.
`exp`	*Expiration*	Timestamp Unix final que encerra a vigência da autorização (tempo de vida estrito de 15 minutos).
`act`	*Action*	Ação delegada ao dispositivo físico (`UNLOCK_DOOR`).
`fp`	*Device Fingerprint*	Hash criptográfico vinculado ao smartphone do corretor (SATANASAOWAPAK; MANASATHIEN; TREEBUPACHATSAKUL, 2021), impedindo transferências.
`sig`	*Digital Signature*	Assinatura de 64 bytes gerada pelo PDP com a chave privada mestre Ed25519 sobre os demais campos.

Fonte: Elaborado pelo autor (2026).

3.5.4 Algoritmo de Verificação Local no ESP32

Ao receber o payload serial via interface de leitura física (óptica ou serial), o firmware do ESP32 submete a mensagem a uma bateria determinística de testes. O fluxograma da Figura 3 sintetiza o encadeamento das decisões.

Figura 3 – Fluxograma de validação determinística de tokens offline no microcontrolador ESP32.



Fonte: Elaborado pelo autor (2026).

A validação cumpre cinco estágios sequenciais com término antecipado em caso de incon-

sistência:

1. **Verificação de Destino (`dev`):** Compara o valor contido no campo `dev` com o identificador único armazenado no firmware do ESP32. Se divergente, rejeita o token por inadequação de unidade física.
2. **Verificação Criptográfica (`sig`):** Invoca a biblioteca nativa `mbedtls` para recalcular a verificação assimétrica da assinatura sobre os campos declarados a partir da chave pública armazenada. A alteração de um único bit invalida a verificação.
3. **Verificação Temporal (`nbf` e `exp`):** Compara a hora informada pelo relógio interno (ou sincronizada pelo token) com a janela de validade permitida. Acessos antes de `nbf` ou posteriores a `exp` são rejeitados.
4. **Verificação de Unicidade (`jti`):** Consulta a memória não-volátil (NVS) do microcontrolador para verificar se o identificador `jti` já consta na lista de tokens consumidos.
5. **Atuação Mecânica:** Atendidos todos os requisitos prévios, o firmware grava o `jti` no buffer histórico, aciona o relé solenoide pelo período regulamentar de 5 segundos, acende o LED verde de confirmação e emite um sinal sonoro simples no *buzzer*.

3.5.5 Prevenção contra Ataques e Gestão do Buffer Anti-Replay

Para garantir que a captura ou gravação do payload não permita aberturas subsequentes não autorizadas, o sistema adota medidas defensivas estruturais descritas no Quadro 7.

A gestão do buffer anti-replay baseia-se em uma estrutura circular alocada na memória não volátil (NVS) do ESP32 com capacidade para reter até 200 identificadores `jti`. Considerando que o tempo de vida máximo de cada token restringe-se a 15 minutos (900 segundos), a retenção de 200 registros oferece proteção integral contra repetição sem acarretar sobrecarga de memória (ocupando menos de 8 KB na partição de dados).

3.6 Fluxo de Operação de Ponta a Ponta

A operação do ecossistema de controle de acesso divide-se em três etapas coordenadas: emissão online do token pela nuvem, validação local offline no imóvel e sincronização assíncrona de auditoria. A Figura 4 exibe o diagrama de sequência detalhado que rege a interação entre os componentes.

3.6.1 Fase 1: Solicitação e Emissão do Token (Online)

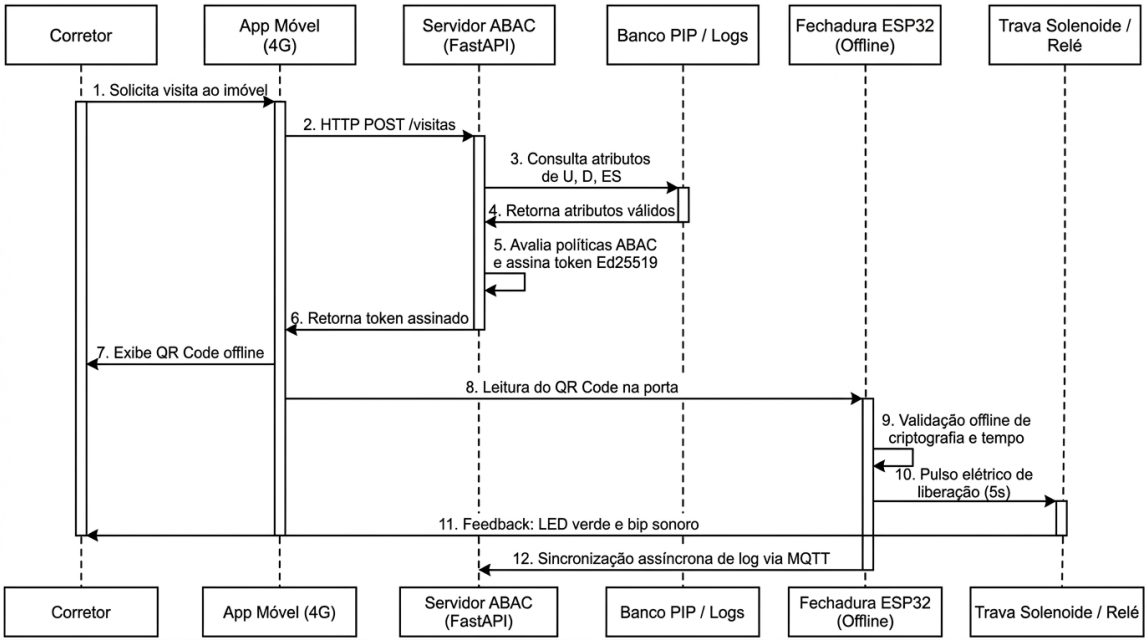
1. Ao aproximar-se do imóvel, o corretor aciona o botão de abertura no aplicativo instalado em seu smartphone com conectividade celular (4G/5G).

Tabela 7 – Matriz de contramedidas de segurança implementadas contra vetores de ataque.

Vetor de Ataque	**Descrição do Ataque**	**Mecanismo de Defesa do Artefato**
Replay Attack	Invasor intercepta o código QR exibido e tenta apresentá-lo novamente ao leitor.	O `jti` é gravado em buffer circular mantido na memória Flash NVS. Nova tentativa é rejeitada.
Token Expirado	Uso de credencial legítima fora do horário acordado da visita.	Verificação do timestamp de expiração (`exp`) com descarte automático de tokens com TTL excedido.
Adulteração de Payload	Tentativa de forjar horário de término ou trocar identificador de imóvel no arquivo JSON.	A assinatura Ed25519 é invalidada matematicamente; o microcontrolador recusa a leitura.
Imóvel Incorreto	Tentativa de empregar autorização emitida para a Unidade A para abrir a Unidade B.	O identificador do dispositivo (`dev`) diverge da identidade estática da fechadura.
Compartilhamento	Corretor envia captura de tela da autorização para terceiro não credenciado.	O hash `fp` vincula o token ao dispositivo móvel; o app não renderiza tokens em aparelhos não autorizados (SATANASAOWAPAK; MANASATHIEN; TREEBUPACHATSAKUL, 2021).
Subtração do Nó IoT	Furto do hardware para extração física de memória e clonagem de chaves.	O microcontrolador guarda apenas a chave pública; chaves privadas permanecem isoladas no servidor em nuvem.

Fonte: Elaborado pelo autor (2026).

Figura 4 – Diagrama de sequência ponta a ponta do processo de requisição, validação e auditoria de visitas.



Fonte: Elaborado pelo autor (2026).

2. O aplicativo despacha uma requisição HTTP via TLS pelo endpoint `</api/v1/access/request-token>` ao servidor central, enviando as credenciais do usuário, identificador do imóvel e a assinatura do dispositivo móvel.

3. O PDP recebe os dados e interroga o banco relacional (PIP) para obter a situação cadastral do corretor, restrições do condomínio e confirmação do agendamento.

4. O motor ABAC processa as condições declaradas na política ativa.

5. Havendo conformidade, o módulo criptográfico gera o payload com identificador `jti` novo, calcula a assinatura digital com a chave privada mestre Ed25519 e retorna o pacote codificado em JSON com código HTTP 200. Caso as regras sejam violadas, o servidor devolve código HTTP 403 contendo a justificativa da negação.

6. O aplicativo recepciona o token, armazena-o no cache local seguro e projeta na tela do aparelho um código QR dinâmico contendo o payload serializado.

3.6.2 Fase 2: Apresentação e Validação Local (Offline)

1. O corretor posiciona a tela do celular diante da interface de leitura associada ao microcontrolador ESP32 na porta do imóvel.

2. O microcontrolador processa a leitura dos caracteres e reconstrói o payload em memória.

3. O firmware executa a bateria de validação descrita na Seção 3.5.4: checagem do identificador do dispositivo (`dev`), verificação matemática da assinatura com a chave pública instalada, conferência da janela de validade (`nbf` e `exp`) e busca do `jti` no buffer anti-replay.

4. Sendo a credencial considerada íntegra e tempestiva, o pino GPIO 23 é configurado em nível lógico alto, excitando a bobina do relé que retrai o pino solenoide da fechadura por 5 segundos. Simultaneamente, o LED verde (GPIO 2) é aceso e o *buzzer* (GPIO 18) emite um bipe curto.

5. O evento de abertura bem-sucedida é registrado na memória NVS local com o respectivo `jti` para preservar o histórico operacional caso a alimentação elétrica seja reiniciada.

3.6.3 Fase 3: Sincronização Assíncrona e Auditoria

1. Concluída a abertura física, o aplicativo do corretor gera um recibo criptográfico assinado contendo o `jti` empregado e o timestamp de efetivação.

2. O smartphone publica o recibo no broker MQTT centralizado (Eclipse Mosquitto) no canal `imobiliaria/auditoria/acessos`, utilizando conexão celular móvel e nível de serviço QoS 1 (*at least once*).

3. O serviço de auditoria em nuvem coleta a mensagem e persiste a trilha de evento na base corporativa, associando a abertura à conta do corretor para eventual auditoria forense.

3.7 Stack Tecnológica e Especificação do Firmware

3.7.1 Mapeamento dos Componentes Tecnológicos

A seleção de tecnologias orientou-se por critérios de reprodutibilidade científica, desempenho de processamento e padronização com a literatura de IoT. O Quadro 8 resume os elementos componentes da solução.

Tabela 8 – Mapeamento da pilha tecnológica empregada no desenvolvimento do artefato.

Camada / Módulo	**Tecnologia Selecionada**	**Justificativa Técnica e Acadêmica**
Nó da Fechadura (PEP)	ESP32 DevKit v1 (Xtensa LX6 Dual-Core 240 MHz)	Arquitetura consolidada na literatura de automação e segurança IoT residencial (VARDAKIS et al., 2024).
Linguagem do Firmware	C/C++ sobre PlatformIO / Framework Arduino	Controle determinístico de memória e integração à biblioteca criptográfica embarcada `mbedtls`.
Servidor de Políticas (PDP)	Python 3.11+ com FastAPI	Arquitetura assíncrona ASGI de alto rendimento, tipagem com Pydantic e geração automática de especificações OpenAPI.
Biblioteca Criptográfica	PyNaCl (Servidor) e mbedtls (ESP32)	Implementações padronizadas do algoritmo Ed25519 imunes a vulnerabilidades de implementação manual.
Broker de Mensageria	Eclipse Mosquitto v2.0+	Padrão aberto com suporte nativo a MQTT v3.1.1/v5.0, baixo consumo de memória ($<$ 10 MB) e garantia QoS 1.
Ambiente de Simulação	Wokwi IoT Simulator	Plataforma com emulação de registradores do ESP32, suporte a rede virtual e conexão com periféricos externos.
Interface do Corretor	Progressive Web App (PWA) em HTML5/JS	Permite acesso multiplataforma via navegador móvel sem fricção de distribuição em lojas de aplicativos.
Ferramentas de Carga	Locust e Pytest	Automação de testes de estresse, injeção de requisições concorrentes e mensuração de percentis de latência.

Fonte: Elaborado pelo autor (2026).

3.7.2 Organização Modular do Firmware no ESP32

O software executado no nó eletrônico foi estruturado em três módulos independentes:

`crypto_verifier.cpp`: Responsável pelo subsistema criptográfico. Contém a chave pública mestre de 32 bytes (`SERVER_PUBLIC_KEY`) gravada em memória de programa (`PROGMEM`). Inicializa as estruturas da biblioteca `mbedtls` e expõe o método de validação `verify_ed25519_signature(payload, signature, pubkey)`.

`token_validator.cpp`: Gerencia a interpretação semântica dos dados. Utiliza a biblioteca `ArduinoJson` com alocação estática de memória (`StaticJsonDocument`) para evitar

fragmentação de heap. Realiza o confronto do campo `dev`, checagem de vigência temporal e iteração sobre a lista encadeada anti-replay mantida na partição NVS.

`lock_actuator.cpp`: Isola a interface com os atuadores e sinalizadores físicos. Controla os estados dos pinos digitais GPIO, definindo tempos de retenção do relé por temporizadores não bloqueantes baseados na função `millis()`, evitando travamento de processamento.

3.7.3 Endpoints e Motor de Inferência em FastAPI

O backend construído sobre FastAPI disponibiliza três pontos de entrada principais:

- `POST /api/v1/access/request-token`: Endpoint principal de requisição. Recebe as credenciais do corretor, ID do imóvel e dados contextuais. Aciona a função de inferência ABAC, consulta a base PostgreSQL/SQLite e, em caso de decisão afirmativa, emprega o método `crypto_sign_detached` da biblioteca `PyNaCl` para produzir a assinatura do token.
- `PATCH /api/v1/corretores/{id}/status`: Ponto de gestão cadastral utilizado por administradores. Permite alterar o status de um corretor de `ATIVO` para `SUSPENSO`. Modificações refletem-se instantaneamente no banco relacional, bloqueando emissões subsequentes de tokens.
- `GET /api/v1/imoveis/{id}/logs`: Consulta a série histórica de acessos registrados para uma determinada unidade imobiliária, viabilizando relatórios gerenciais de auditoria.

3.7.4 Estrutura de Mensageria e Tópicos MQTT

Para garantir a rastreabilidade exigida pelos requisitos do artefato, as mensagens de eventos transitam pelo broker Eclipse Mosquitto estruturadas sob uma árvore hierárquica padronizada de tópicos:

Listing 3.3 – Estrutura hierárquica de tópicos MQTT empregada no sistema.

```
1  imobiliaria/
2  +-- imoveis/{imovel_id}/
3  |   +-- status        # Telemetria: Online/Offline/Bateria
4  |   +-- revogacoes    # Broadcast de revogacao emergencial
5  |   +-- telemetria    # Tempo de resposta e diagnosticos
6  +-- auditoria/
7  |   +-- acessos       # Recibos de acessos executados
8  |   +-- alertas       # Tentativas com token invalido
9  +-- comandos/{imovel_id}/
10     +-- emergencia    # Bloqueio forcado administrativo
```

O pacote de dados remetido ao canal `imobiliaria/auditoria/acessos` adota o formato exposto no Código 3.4, garantindo integridade e dados para a posterior composição dos relatórios de avaliação.

Listing 3.4 – Formato do pacote de auditoria despachado via MQTT QoS 1.

```
{
  "event_id": "evt_998124_ack",
  "timestamp": 1774204850,
  "imovel_id": "lock_esp32_imovel_042",
  "corretor_id": "corretor_id_8472",
  "jti_utilizado": "a7f4b892-91c2-4e88-9d21-f09b578c92a1",
  "resultado": "ACESSO_CONCEDIDO",
  "latencia_validacao_ms": 2.45,
  "latencia_comunicacao_ms": 178.30
}
```

3.8 Ambiente de Simulação Virtual no Wokwi

3.8.1 Justificativa Metodológica da Prototipagem Virtual

A avaliação de sistemas de controle de acesso baseados em microcontroladores através de simulação virtual constitui procedimento respaldado na literatura científica recente (RESEARCHERS, 2024). A simulação em plataforma controlada oferece vantagens experimentais frente à montagem física manual:

1. **Reprodutibilidade científica:** Ensaios de latência, verificação de limites de memória e estresse com tokens adulterados podem ser reproduzidos de maneira idêntica por outros pesquisadores sem variações térmicas ou ruídos mecânicos de protoboards.

2. **Isolamento de variáveis espúrias:** Permite avaliar o tempo de computação algorítmica do microcontrolador sem interferências de oscilações elétricas na trava solenoide ou degradação de sinal óptico.

3. **Viabilidade experimental em bancada acadêmica:** Elimina a necessidade de aquisição de travas industriais de alto custo durante as rodadas de testes sistemáticos da monografia.

3.8.2 Mapeamento do Circuito Eletrônico e Pinout

O nó virtual foi modelado no Wokwi Simulator utilizando o módulo virtual ESP32 DevKit v1. As ligações elétricas aos periféricos virtuais utilizam o mapa de pinos indicado no Quadro 9.

A topologia das conexões entre pinos, componentes e referências de aterramento (GND) é parametrizada no arquivo descritivo `diagram.json`, reproduzido integralmente no Código 3.5.

Tabela 9 – Mapeamento dos pinos GPIO e periféricos no circuito virtual ESP32.

Pino GPIO	Direção	Dispositivo Conectado	Comportamento e Função
GPIO 23	Saída (Digital)	Módulo Relé Solenoide	Nível ALTO comuta o relé por 5 segundos para liberar a trava.
GPIO 2	Saída (Digital)	LED Verde	Pulso luminoso que indica validação e liberação do acesso.
GPIO 4	Saída (Digital)	LED Vermelho	Sinaliza rejeição (token inválido, expirado ou unidade divergente).
GPIO 18	Saída (PWM)	Buzzer Piezoelétrico	Emite um tom agudo para sucesso e dois graves para rejeição.
GPIO 16 / 17	Entrada/Saída	Porta Serial / Leitor RX/TX	Recepção dos dados brutos correspondentes à leitura do código.

Fonte: Elaborado pelo autor (2026).

Listing 3.5 – Arquivo descritivo diagram.json do circuito virtual no simulador Wokwi.

```
{
  "version": 1,
  "author": "Controle de Acesso IoT - TCC",
  "editor": "wokwi",
  "parts": [
    { "type": "wokwi-esp32-devkit-v1", "id": "esp", "top": 0, "left": 0, "attrs": {} },
    { "type": "wokwi-relay-module", "id": "relay", "top": 100, "left": 150, "attrs": {} },
    { "type": "wokwi-led", "id": "led_green", "top": -50, "left": 120, "attrs": { "color": "green" } },
    { "type": "wokwi-led", "id": "led_red", "top": -50, "left": 160, "attrs": { "color": "red" } },
    { "type": "wokwi-buzzer", "id": "buzzer", "top": -50, "left": 200, "attrs": {} }
  ],
  "connections": [
    [ "esp:TX", "relay:IN", "green", [ "h20", "v40" ] ],
    [ "esp:D2", "led_green:A", "green", [ "h10", "v-30" ] ],
    [ "esp:D4", "led_red:A", "red", [ "h10", "v-30" ] ],
    [ "esp:D18", "buzzer:2", "blue", [ "h10", "v-30" ] ],
    [ "esp:GND.1", "relay:GND", "black", [ "h0" ] ],
    [ "esp:GND.1", "led_green:C", "black", [ "h0" ] ],
    [ "esp:GND.1", "led_red:C", "black", [ "h0" ] ],
    [ "esp:GND.1", "buzzer:1", "black", [ "h0" ] ]
  ]
}
```

3.9 Cenários de Demonstração DSR

Em alinhamento aos critérios de aceitação do Objetivo Específico 2 (OE2) definidos na introdução do trabalho, o artefato é demonstrado e validado em três cenários operacionais representativos.

3.9.1 Cenário 1: Concessão de Acesso Válido em Horário Permitido

Este cenário avalia o comportamento do ecossistema sob fluxo nominal de operação sem incidentes.

- **Pré-condições:** Corretor com cadastro ativo; imóvel catalogado como disponível para visitação; requisição submetida dentro do horário comercial e com agendamento homologado.
- **Procedimento de Ensaio:** O corretor despacha a solicitação pelo app, recebe o token assinado e apresenta o código QR ao microcontrolador.
- **Critério de Sucesso:** O microcontrolador conclui a validação da assinatura Ed25519 em tempo inferior a 10 ms, aciona o relé por 5 segundos com sinalização verde e publica o recibo de auditoria no broker MQTT sem perdas de pacotes.

3.9.2 Cenário 2: Negação de Acesso sob Condições Inválidas e Tentativas de Ataque

Avalia a robustez do firmware na rejeição sumária de tentativas irregulares ou maliciosas de acesso. A matriz de ensaios negativos divide-se em quatro casos de teste (CT), expressos no Quadro 10.

Tabela 10 – Matriz de ensaios do Cenário 2 (Rejeição de acessos inválidos e ataques).

ID	Tipo de Teste	Estímulo Injetado no Sistema	Resultado Esperado
CT-2.1	Token Expirado	Apresentação de credencial íntegra, porém com horário posterior a `exp` ($>$ 15 minutos).	Rejeição no microcontrolador, ativação do LED vermelho e gravação de log de expiração.
CT-2.2	Imóvel Divergente	Apresentação de token autêntico do Imóvel A na fechadura do Imóvel B.	Detecção de disparidade no campo `dev`; bloqueio imediato do relé.
CT-2.3	Assinatura Forjada	Alteração induzida de 1 bit no conteúdo do payload JSON antes do envio.	A função `verify_ed25519` retorna falso; abertura categoricamente negada.
CT-2.4	Ataque de Repetição	Reenvio consecutivo do mesmo token válido que já acionou o sistema anteriormente.	Detecção do identificador `jti` no buffer NVS; bloqueio por duplicidade.

Fonte: Elaborado pelo autor (2026).

Critério de Aceitação: Obter índice de eficácia de 100% de bloqueio em todas as tentativas anômalas, com ausência de qualquer falso positivo de liberação do relé.

3.9.3 Cenário 3: Revogação Emergencial de Credenciais

Investiga a capacidade do sistema em cessar privilégios concedidos a corretores suspensos administrativamente.

- **Procedimento de Ensaio:** Um gestor altera a situação cadastral de um corretor ativo para `SUSPENSO` via painel administrativo. Imediatamente após a alteração, o corretor tenta emitir um token de visita para um imóvel disponível.
- **Critério de Sucesso:** O PDP barra a requisição de emissão devolvendo código HTTP 403. Para tokens já emitidos em trânsito, a duração estrita do TTL (15 minutos) e o despacho de broadcast via tópico MQTT de revogação asseguram a invalidação temporal confinada da credencial.

3.10 Métricas e Procedimentos de Avaliação

3.10.1 Métricas Quantitativas de Desempenho e Segurança

Para a composição dos resultados experimentais (Capítulo 4), foram definidas oito variáveis quantitativas fundamentadas em parâmetros comumente adotados na literatura de sistemas de controle de acesso IoT (AMEER et al., 2022; VARDAKIS et al., 2024; RESEARCHERS, 2024). O Quadro 11 consolida as variáveis, métodos de medição e metas.

3.10.2 Procedimento Experimental e Tratamento Estatístico

A coleta experimental estrutura-se sobre uma bateria de 50 repetições para cada teste individual de latência, minimizando a influência de anomalias operacionais e garantindo significância estatística.

Os dados brutos coletados são tabulados e processados por scripts analíticos em Python (bibliotecas Pandas e SciPy), gerando os seguintes parâmetros descritivos:

- Média aritmética (μ) e desvio padrão amostral (σ);
- Valores extremos (mínimo e máximo observados);
- Distribuição percentil ($p50$, $p95$ e $p99$), evidenciando a cauda longa de tempo de resposta sob condições adversas de simulação;
- Matriz de confusão para validação das taxas de falsos positivos (concessões indevidas) e falsos negativos (bloqueios indevidos).

Tabela 11 – Métricas quantitativas para avaliação experimental do artefato.

#	**Variável / Métrica**	**Unidade**	**Método de Coleta e Instrumentação**	**Meta**
M1	Latência de Decisão ABAC (PDP)	ms	Timestamp de início e término da inferência lógica no FastAPI.	< 50 ms
M2	Tempo de Assinatura Criptográfica	ms	Medição com biblioteca `time` sobre `crypto_sign_detached`.	< 5 ms
M3	Tempo de Verificação no ESP32	ms	Leitura com função `micros()` no firmware antes e após verificação Ed25519.	< 10 ms
M4	Latência Total de Resposta (*End-to-End*)	ms	Intervalo decorrido entre o clique no app móvel e o acendimento do LED verde.	< 500 ms
M5	Consumo de Memória RAM (Heap)	KB	Monitoramento dinâmico no firmware via chamada `ESP.getFreeHeap()`.	< 120 KB usados
M6	Ocupação de Memória Flash (ROM)	%	Relatório de vinculação estática do compilador PlatformIO.	$< 35\%$ da flash
M7	Vazão de Mensagens no Broker MQTT	msg/s	Teste de estresse com Locust publicando eventos de auditoria concorrentes.	> 100 msg/s
M8	Taxa de Bloqueio em Tentativas Anômalas	%	Proporção de bloqueios efetivos nos casos de teste CT-2.1 a CT-2.4.	100%

Fonte: Elaborado pelo autor (2026).

Os resultados brutos e as discussões comparativas com os trabalhos relacionados do estado da arte são apresentados e examinados no Capítulo 4.

4 Resultados e Discussão

4.1 Introdução

Apresente gráficos, tabelas e análises dos resultados obtidos.

4.2 Apresentação de resultados

5 Conclusão

Apresente:

- resumo dos resultados - contribuição da pesquisa - limitações - sugestões para trabalhos futuros

5.1 Trabalhos futuros

Referências

AMEER, S. et al. An attribute-based approach toward a secured smart-home IoT access control and a comparison with a role-based approach. *Information*, v. 13, n. 2, p. 60, 2022.

AUTHORS, V. Continuous authentication for IoT smart home environments. *Network Security*, 2022.

_____. Reconceptualizing smart home automation: Enforcing secure and user-friendly communication for delegating general access. In: *International Conference on Advances in Computing, Communication and Control Methods (ICACCM)*. [S.l.: s.n.], 2024.

_____. IoT-based smart lock with real-time person detection using YOLOv5 and mobile app integration. *RCSI*, 2025.

HAN, D. et al. Trustworthiness and a zero leakage OTMP-P2L scheme based on NP problems for edge security access. *Sensors*, v. 20, n. 8, p. 2231, 2020.

_____. Offline authentication scheme based on blockchain technology for smart lock. In: *Proceedings of the 2018 ACM International Conference*. [S.l.: s.n.], 2018.

HEVNER, A. R. et al. Design science in information systems research. *MIS Quarterly*, v. 28, n. 1, p. 75–105, 2004.

PEFFERS, K. et al. A design science research methodology for information systems research. *Journal of Management Information Systems*, v. 24, n. 3, p. 45–77, 2007.

RESEARCHERS, I. A survey on smart home authentication: Toward secure, multi-level and interaction-based identification. *IEEE Xplore*, 2021.

_____. 5G-SSAAC: Slice-specific authentication and access control in 5G. *IEEE Xplore*, 2022.

RESEARCHERS, M. Performance evaluation of IoT microcontrollers for access control systems via simulation. *MDPI*, 2024.

SATANASAOWAPAK, C. et al. Residential access control system using QR code and the IoT. *International Journal of Electrical and Computer Engineering (IJECE)*, v. 11, n. 4, p. 3267–3274, 2021.

SILVA, V. C. et al. IoT and blockchain for smart locks. *IEEE Xplore*, 2023.

VARDAKIS, G. et al. Review of smart-home security using the internet of things. *Electronics*, v. 13, n. 16, p. 3343, 2024.

ZHOU, Y. et al. Perils and mitigation of security risks of cooperation in Mobile-as-a-Gateway IoT. In: *Proceedings of the 2022 ACM SIGSAC Conference on Computer and Communications Security (CCS '22)*. [S.l.: s.n.], 2022.